

2.9 Transaction Business Controls

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	•
Control Definition Control Objective: Ensure outbound transaction activity within the expected bounds of normal business. In-scope components: - outbound business transactions Note: Outbound business transactions can originate from components such as a GUI, an interface, a (client) connector or an operator PC used to connect to other internal components or to a service provider. Controls are not necessarily performed on those components (in fact, these controls can even be business controls performed outside of the secure zone). Business transaction refers to instructions leading to payment. Reliance on other relevant recent (business) assessment, audit or regulator answers to confirm effectiveness of the control is an option³³. Risk Drivers: - undetected anomalies or suspicious activity						
Implementation Guidance Control Statement: Implement transaction detection, prevention, or validation controls, or a combination of them to ensure outbound transaction activity within the expected bounds of normal business. Control Context: Implementing business controls that restrict business transactions to the fullest extent possible reduces the opportunity for the sending (outbound) and, optionally, receiving (inbound) of fraudulent transactions. These restrictions are best determined through an analysis of normal business activity. Parameters can then be set to restrict business to acceptable thresholds based on “normal” activity. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives). - Implement controls that will detect, prevent, or additionally validate the flow of business transactions against the expected bounds of normal business. Examples of potential controls can include any or a combination of the following five options (where (1) and (2) are preventive controls; (4) is an on-line detective control; (3) and (5) are post-event validation controls): (1) limiting traffic outside of business hours Note: This measure may not be applicable to some users: as business hours are organisational and business unit-specific, multiple start and finish times (business hours) may need to be supported or no specific range can be defined for systems used on a 24-hour basis. In cases of 24-hour centralised Swift processing, limit or monitor transactions as appropriate to support business as usual considering the other elements. - Consider restricting transaction submissions and approvals outside of normal business hours³⁴.						

³³ Although reliance on recent certification, audit or assessment is allowed for any CSP control as per the Independent Assessment Framework (IAF), it is even more relevant in this control.

³⁴ Limiting or dully controlling sessions outside of normal business hours can introduce delays allowing to intercept/recall fraudulent transactions before their potential immediate processing and ultimately cash-out.

- Consider enabling active FIN sessions to business hours only (for example, using automated logical terminal sessions log out at the end of the business day).

Note: Suspicious messages can be blended in with legitimate traffic during business hours. Therefore, always limit or monitor transactions as appropriate, to support business as usual activities considering the next elements.

(2) limiting traffic beyond normal business amount ranges

- Consider restricting transactions outside of user-defined amount limits. Such limits can be specified globally, per region, currency, transaction type or known correspondents, in line with functionalities offered by the used Swift-related interface, application or service. Putting on-hold restricted transactions for additional/off-line validation and approval (in line with separation of duties as per control 5.1) is deemed a valid control.

(3) performing end-of-day and (possibly) intra-day validations or reconciliations through any or a combination of the following

- Consider implementing a process to issue and check confirmation messages (for example, to check that (i) the MT 900 and MT 910, or (ii) their MX camt.054 equivalent confirmations or (iii) the Swift Universal Confirmations match the transactions that have occurred on the accounts or through potential online queries, for intra-day Nostro or payments reconciliation).
- Consider reconciling the entity's accounting records with end-of-day statement messages (for example, using MT 940 and MT 950, their MX camt.053 equivalent, or through potential online queries for end-of-day Nostro reconciliation).
- Consider reconciling daily (and possibly intra-day) messages that are sent to/from the back office and to/from the Swift Network.

(4) performing central checks on payments to spot potential abnormal behaviour

- Consider tracking session numbers within the messaging interface to make sure that the sequential session numbering is intact with no unexpected gaps.
- Consider monitoring uncharacteristic transactions (for example, exceptionally high amounts or cumulative amounts, unusual beneficiaries, senders, or currencies) based on self-determined criteria.

(5) performing independent reconciliation with transaction data securely obtained from a secondary source (either internal or external, such as reports from service providers) or verifying that the transaction is genuine with the emitter or the recipient (or both).

- Potential adverse events are analysed and acted upon when relevant, as per user's Cyber Incident response Plan (control 7.1).

Optional Enhancements:

- Application and operating system accounts are restricted from login attempts that occur outside of the expected role-specific operational hours.
- Implement controls to ensure inbound transaction activity within the expected bounds of normal business.
- Implement controls to other sensitive transactions not limited to payments.
- Consider combining several types of controls (considering (1) and (2) as preventive control; (4) as on-line detective control; (3) and (5) as post-event validation control)

2.10 Application Hardening

Control Type: Mandatory	Applies to architecture:	A1 •	A2 •	A3 •	A4	B
<u>Control Definition</u> Control Objective: Reduce the attack surface of Swift-related components by performing application hardening on the Swift-compatible messaging and communication interfaces, the Swift connector and related applications. In-scope components: • messaging interface • communication interface • GUI • SwiftNet Link • Swift connector Risk Drivers: • excess attack surface • exploitation of insecure application configuration						
<u>Implementation Guidance</u> Control Statement: All messaging interfaces and communication interfaces products within the Swift secure zone are Swift-compatible. Application security hardening is conducted and maintained on all in-scope components. Control Context: Application hardening applies the security concept of “least privilege” to an application by disabling features and services that are not required for normal operations. This process reduces the application capabilities, features, and protocols that may be used during an attack. The process also makes sure that potential default credentials are changed. In addition, Swift runs a Compatible Interface Programme to make sure interfaces are aligned with current practices and to give the customer additional assurance, guarantees, and better visibility regarding individual product capabilities. Upon the successful validation of the test results by the Swift Test Authority, the interface is published in the Compatible Register. As per the Swift General Terms and Conditions, customers must use a Swift-compatible interface. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user’s implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives). • Make sure the messaging and communication interfaces are Swift-compatible (the list of compatible interfaces is published in the Compatible Register on www.swift.com). – The Swift-compatible interface should meet all the security conformance requirements (mandatory and advisory) defined in the Swift Compatible Interface Programme. ○ If some security conformance requirements are yet to be met, then the user should upgrade to a Swift-compatible interface by implementing at least the minimum mandatory security conformance requirements. ○ The interface provider should be contacted in case of doubts regarding the availability of some security functionalities or their proper configuration and usage. • All in-scope applications are hardened considering one or more of the following:						

- vendor security, operational or configuration guidance (such as the Alliance Security Guidance).
- a local or a regulator's standard security configuration, or controls set of the same rigour as the vendor guidance.
- At a minimum, the application hardening process should do the following:
 - Change default existing passwords.
 - Disable or remove unnecessary user accounts.
 - Disable or restrict unnecessary components, adaptors, or connectivity methods.
 - Securely configure the adapters, connectivity methods, or remote connections.
 - Remove unnecessary packages.
 - Adjust any default configurations known to be vulnerable.
 - Implement MFA for the application administration or security accounts, such as Left and Right Security Officer (LSO/RSO), as per the vendor guidance or manage those accounts as break-glass accounts. Where break-glass account usage must be strictly controlled (with password physically or digitally safe-stored and requiring authorisation before retrieval) and monitored (in line with or as part of the control 6.4). In addition, the passwords must be changed, once used, to ensure accountability, prevent misuse, or account compromise.
- Deviations from the selected hardening configuration (that is, a set of rules) are documented along with the justification for the deviation.
- Credentials and private or bilateral (cryptographic) keys used, and usually stored, by applications to secure flows are protected. This can be achieved through a large spectrum of methods, from definition and usage of secure coding guidelines to the use of specific solutions such as KMS, secured based on the user's risk management).

Optional Enhancement:

- Additional applications installed on the systems that host in-scope components and handle Swift-related data are also subject to considered application hardening as per the vendor recommendations.